

Интернет-разведка

Александр Дорофеев, CISSP, CISA, CISM

Echelon Eyes



@ECHELONEYES

Записи и презентации будут опубликованы в телеграм-канале Echelon Eyes

<https://t.me/EchelonEyes>

Предупреждение

- Рассматриваемые в курсе приемы тестирования защищенности можно отрабатывать только в собственной виртуальной лаборатории в отношении тестовых машин.
- Использование приемов в отношении реальных информационных ресурсов может подпадать под одну из следующих статей УК РФ:
 - УК РФ Статья 272. Неправомерный доступ к компьютерной информации
 - УК РФ Статья 273. Создание, использование и распространение вредоносных компьютерных программ
 - УК РФ Статья 274.1. Неправомерное воздействие на критическую информационную инфраструктуру Российской Федерации
 - УК РФ Статья 274. Нарушение правил эксплуатации средств хранения, обработки или передачи компьютерной информации и информационно-телекоммуникационных сетей



Домашнее задание 1

1. Вступить в группу Сканер-ВС 6 <https://t.me/scanervs> в Telegram
2. Установить VirtualBox <https://www.virtualbox.org/wiki/Downloads>
3. Импортировать Kali Linux <https://www.kali.org/get-kali/#kali-virtual-machines>
4. Создать виртуальную машину (Ubuntu 32 bit) и подключить жесткий диск машины Metasploitable 2
<https://sourceforge.net/projects/metasploitable/>
5. Настроить сеть на двух машинах

План

1. Разведывательный анализ
2. Тактическая задача «Разведка» (Reconnaissance) в матрице MITRE ATT&CK

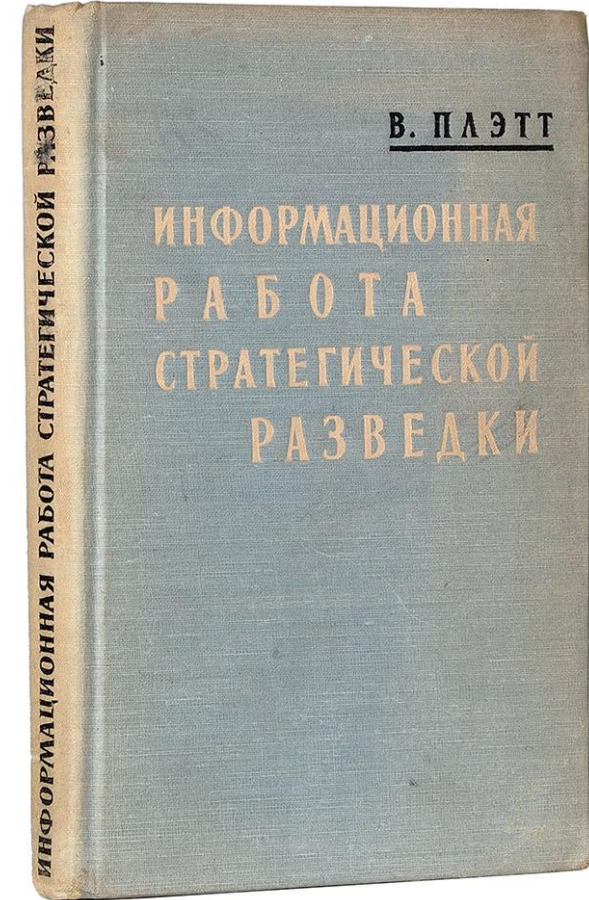
Что такое разведка?

Разведка – инструмент, с помощью которого человек проникает в то, что другой человек пытается скрыть. Возможно и более широкое толкование разведки – выяснение обстоятельств, которые благоприятствуют или препятствуют осуществлению того или иного действия, связанного с риском для замышляющего. («Рука Москвы..» Л.В. Шебаршин, генерал-лейтенант, начальник внешней разведки СССР, и. о. председателя КГБ СССР)



Что интересует настоящих разведчиков?

1. Изучение существующего положения.
2. Изучение возможностей.
3. Изучение намерений.

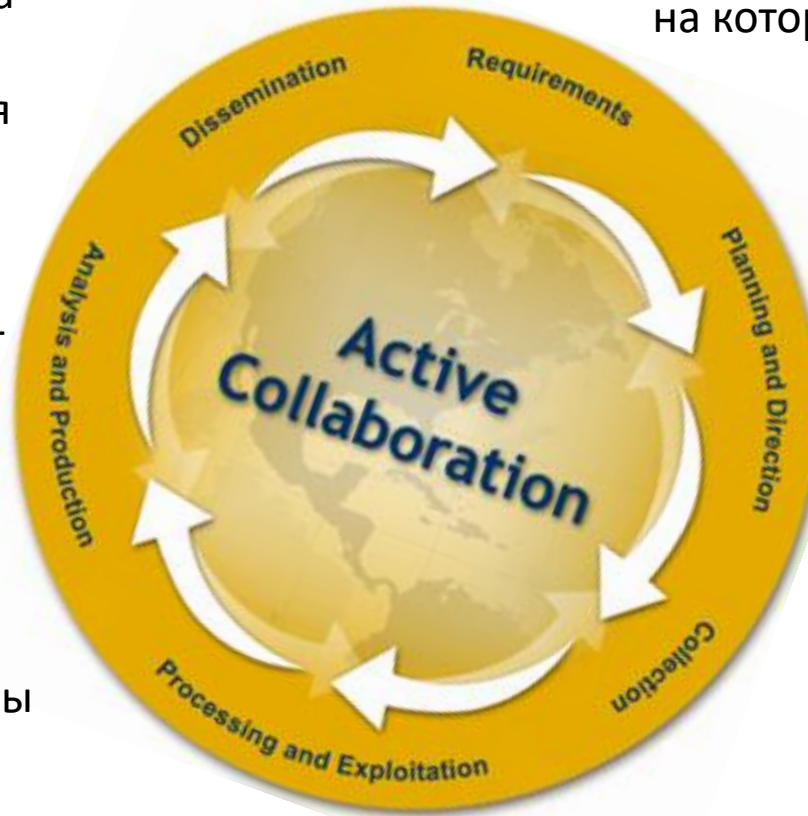


Разведывательный цикл

6. В ходе разработки отчета формулируются выводы, рекомендации, приводятся подтверждающие свидетельства.

Распространение информации предполагает презентацию результатов заинтересованным лицам.

5. Анализ информации нацелен на поиск ответов на поставленные вопросы



1. Формулирование набора вопросов, на которые необходимо найти ответ.

2. В ходе планирования определяется подход к поиску и анализу данных.

3. В ходе сбора данных осуществляется непосредственный сбор данных относительно тех объектов исследования, которые были определены на предыдущем этапе.

4. Обработка данных позволяет извлечь информацию для анализа.

Английские сокращения для обозначения вариантов сбора данных

Wikipedia:

- HUMINT (Human intelligence) – агентурная разведка
- GEOINT (Geospatial intelligence) - геопространственная разведка
- MASINT (Measurement and signature intelligence) – измерительно-сигнатурная разведка
- OSINT (Open-source intelligence) – разведка по открытым источникам
- SIGINT (Signals intelligence) – разведка сигналов
- TECHINT (Technical intelligence) – техническая разведка
- CYBINT (Cyber or digital network intelligence) – разведка в сети
- FININT (Financial intelligence) – финансовая разведка

SOME TYPES OF INTELLIGENCE

Acoustic(al) Intelligence (ACOUSTINT or ACINT)	Imagery Intelligence (IMINT)
Actionable Intelligence	Joint Intelligence
Basic Intelligence	Laser Intelligence (LASINT)
Biographic(al) Intelligence	Measurement and Signature Intelligence (MASINT)
Cartographic Intelligence	Medical Intelligence (MEDINT)
Combat Intelligence	Military Intelligence (MI)
Communications Intelligence (COMINT)	National Intelligence
Counterintelligence	Nuclear Intelligence (NUCINT)
Critical Intelligence	Nuclear Proliferation Intelligence
Current Intelligence	Operational Intelligence (OPINTEL)
Department(al) Intelligence	Optical Intelligence (OPTINT)
Economic Intelligence	Photographic Intelligence (PHOTINT)
Electro-Optical Intelligence (ELECTRO-OPTINT)	P
Electronic Intelligence (ELINT)	P
Energy Intelligence	R
Estimative Intelligence	R
Evasion and Escape Intelligence	R
Finished Intelligence	S
Foreign Counterintelligence (FCI)	S
Foreign Instrumentation Signals Intelligence (FISINT)	S
Foreign Intelligence (FI)	T
Foreign Materiel (FORMAT) Intelligence	T
Geographic(al) Intelligence	T
Human Intelligence (HUMINT)	T

Glossary of Intelligence Terms and Definitions

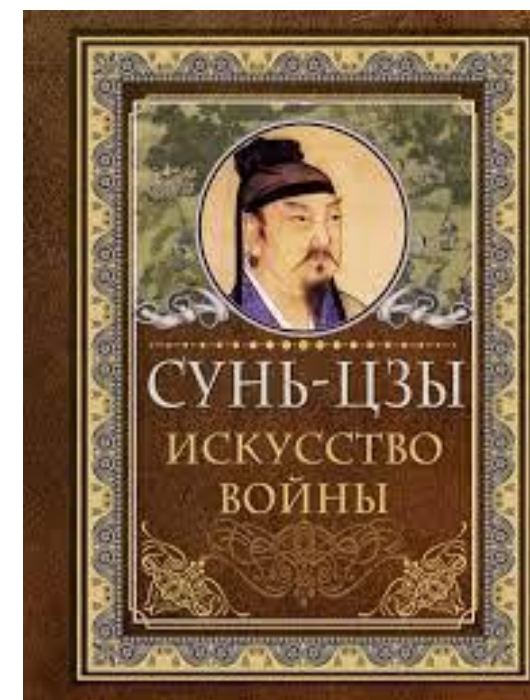
June 15, 1978

Published by the Intelligence Community Staff
For the Director of Central Intelligence

With Advice of the National Foreign
Intelligence Board

Какой *INT?

Поэтому просвещенные государи и мудрые полководцы двигались и побеждали, совершали подвиги, превосходя всех других, потому, что все знали наперед. Знание наперед нельзя получить от богов и демонов, нельзя получить и путем заключения по сходству, нельзя получить и путем всяких вычислений. Знание положения противника можно получить только от людей. (Искусство войны, Сунь-цзы)



приблизительно 380—325 годы до н. э.

OSINT

- OSINT – сбор и анализ информации из публично доступных источников.



OSINT: немного исторических фактов

Wikipedia: OSINT в США берет начало 1941, когда было создано агентство, отвечающее за мониторинг иностранного вещания Foreign Broadcast Monitoring Service (FBMS).

Перед первой мировой войной методы OSINT также активно использовались: «В случае помещения в современных изданиях, журналах или газетах каких-либо сведений о производстве на территории государства военно-инженерных работ немедленно отмечать это в записной книжке» (Е.М. Гришин. Тайная сила разведки Германии).



Социальная инженерия и OSINT

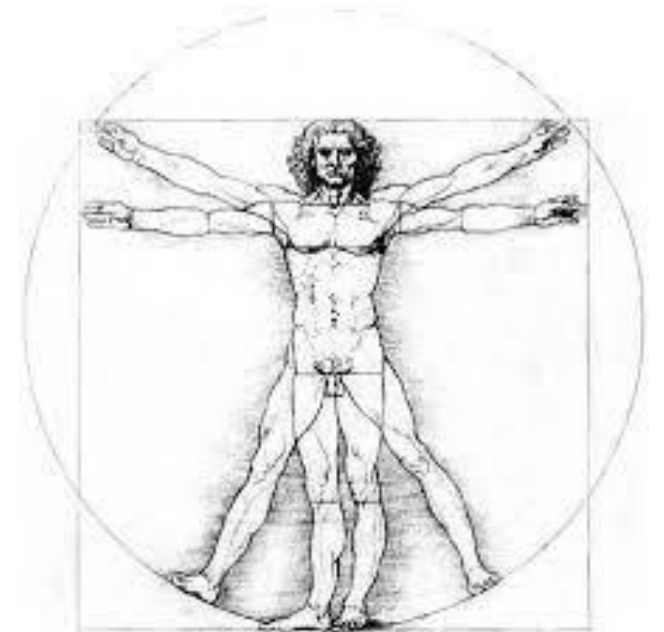


Разведывательный анализ/информационная работа

- Процесс, в ходе которого из большого количества недостаточных и частично ненадежных фактов извлекается максимальная польза. (Плэтт В. Информационная работа стратегической разведки.)
- Применение индивидуальных и коллективных когнитивных методов для взвешивания данных и проверки гипотез..
(https://en.wikipedia.org/wiki/Intelligence_analysis).

Несовершенство человека

1. Начинаем анализ проблемы с формулировки вывода
2. Фокусируемся на решении, которому мы интуитивно отдаем предпочтение
3. Решение, к которому мы интуитивно склоняемся, чаще всего оказывается первым вариантом, который нас устраивает
4. Мы видим мир через призму шаблонов. У каждого из нас формируется набор предубеждений, которые определяют все наши мысли и действия.



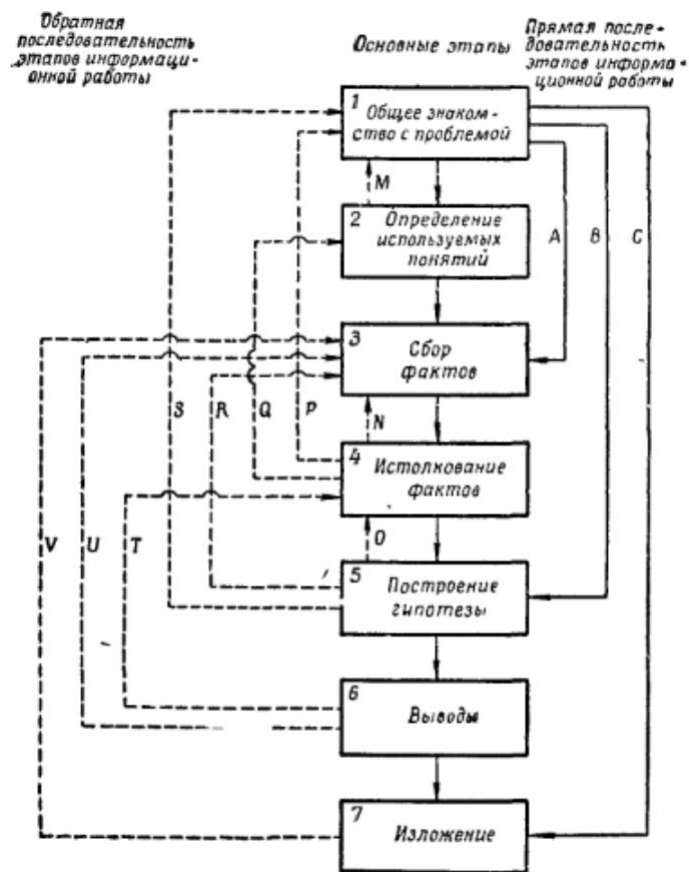
Предвзятость осознанная и неосознанная

- **Предвзятость** – это восприятие, полностью подчиненное предубеждению или определенной точке зрения. Односторонний подход, приводящий к искаженному пониманию реальности.
- **Осознанная предвзятость** – намеренное высказывание одностороннего взгляда или явное следование одностороннему суждению.
- **Неосознанная предвзятость** – искажение мнений или решений факторами, о которых вы даже не подозреваете.

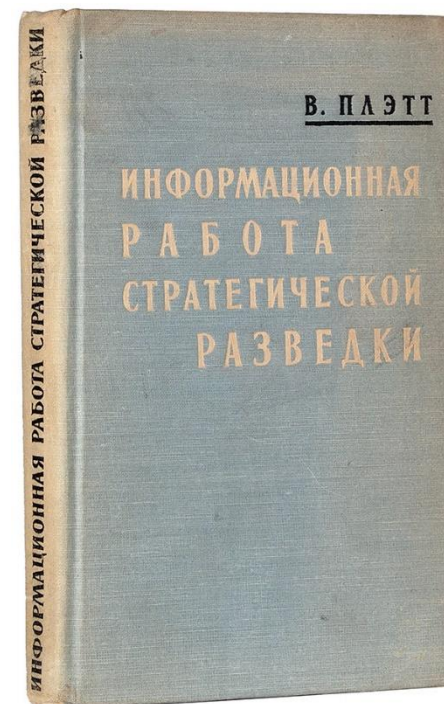
Структурирование

1. Помогает понять суть комплексных проблем
2. Позволяет сравнивать элементы между собой
3. Позволяет фокусироваться на конкретном элементе
4. Помогает сосредоточиться на каждом из элементов по очереди
5. Помогает преодолеть особенности мышления, ведущие к ошибкам в анализе

Последовательность этапов информационной работы



Р и с. 3. Последовательность этапов информационной работы.



ФАКТЫ САМИ ПО СЕБЕ МОГУТ НИЧЕГО НЕ ЗНАЧИТЬ

19

Факт 1.

Иван был онлайн в мессенджере:

22:00 – 22:05

22:15 – 22:20

23:30 – 23:40

Факт 2.

Маша была онлайн в мессенджере:

22:00 – 22:05

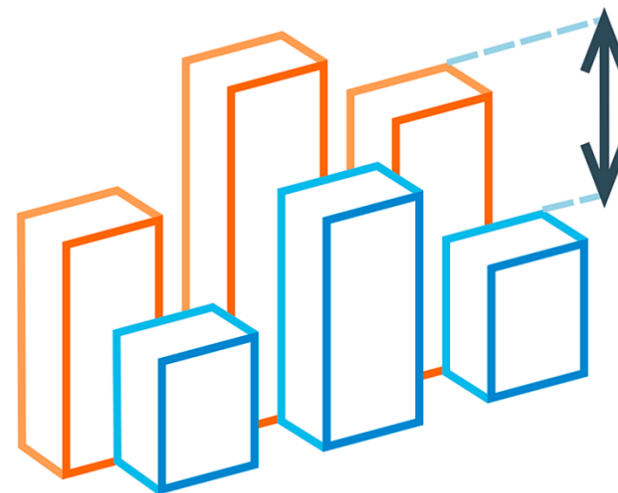
22:15 – 22:20

23:30 – 23:40



Все познается в сравнении

1. Покомпонентное: процент от целого
2. Позиционное: соотношение объектов
3. Временное: изменение во времени
4. Частотное: число объектов в интервалах
5. Корреляционное: зависимость между переменными

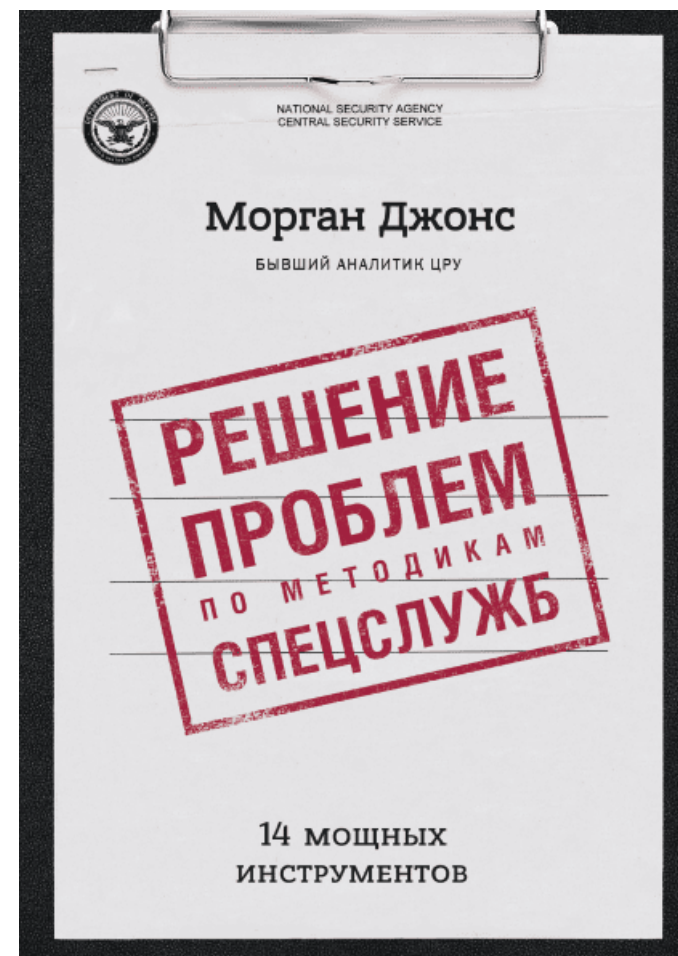


Пример из книги Плэтта

- Изначальный факт: «В 1953 году высшие учебные заведения Советского Союза выпустили 40 000 инженеров»
- Если добавить «В 1947 году в Советском Союзе было подготовлено 15 000, а в 1950 году 28 000 инженеров», то становится понятной динамика.
- Если сопоставить с аналогичными данными США: «В 1947, 1950 и 1953 годах в США подготавливалось соответственно 21 000, 52 000 и 27 000 инженеров», то сразу понятно положение стран по этому вопросу и появляются новые конкретные вопросы.

Structured analytic techniques

1. Новая формулировка проблемы
2. Плюсы, минусы и решения
3. Дивергентное и конвергентное мышление
4. Сортировка, временная последовательность и хронология
5. Диаграмма причинно-следственной связей
6. Матрица
7. Дерево сценариев

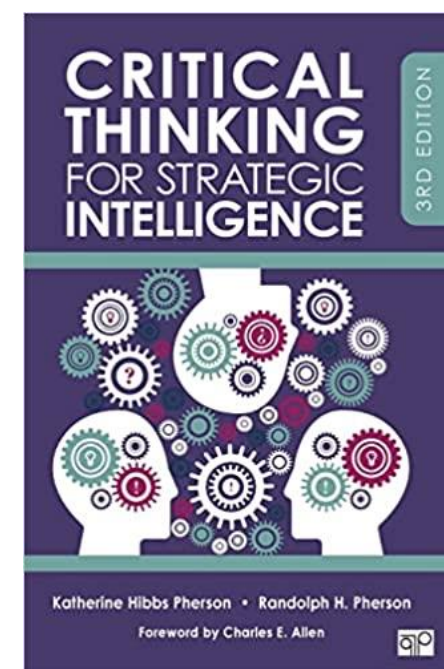
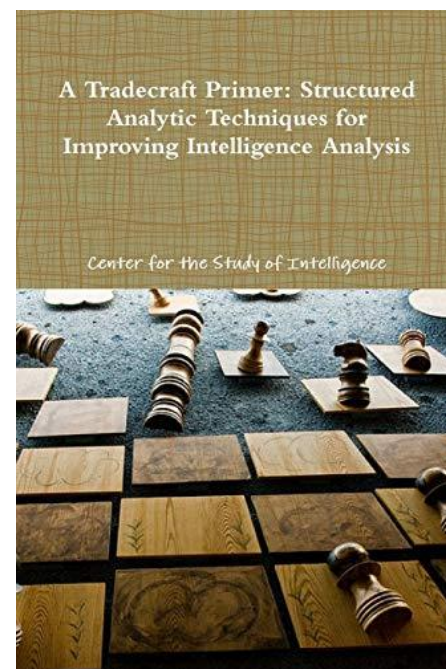
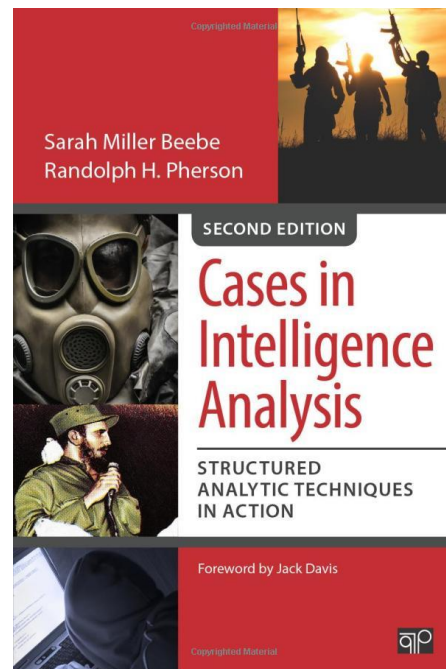
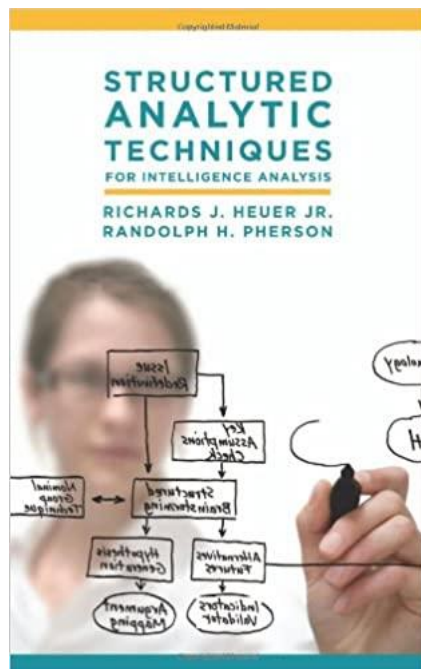


Structured analytic techniques

- 8. Взвешенное ранжирование
- 9. Проверка гипотез
- 10. Адвокат дьявола
- 11. Дерево вероятностей
- 12. Дерево анализа полезности
- 13. Матрица полезности
- 14. Углубленный анализ полезности

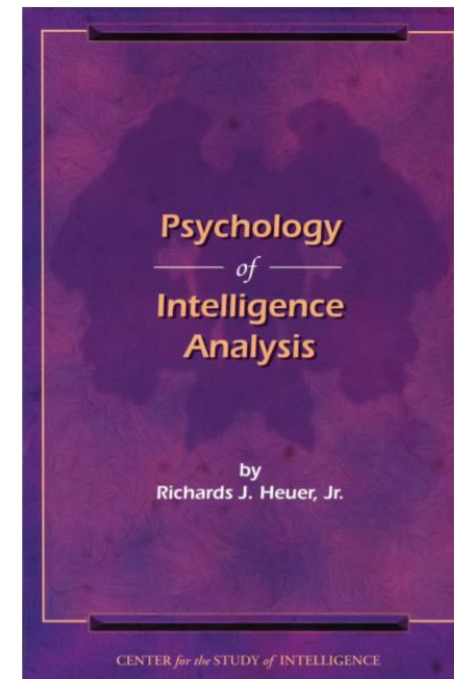


Еще несколько книг



Алгоритм тестирования альтернативных гипотез

1. Зафиксировать гипотезы для анализа.
2. Подготовить список важных свидетельств и аргументов, поддерживающих и противоречащих каждой гипотезе.
3. Подготовить матрицу, сопоставляющую гипотезы со свидетельствами. Провести анализ, насколько свидетельства позволяют определить относительную вероятность каждой гипотезы.
4. Пересмотреть матрицу. При необходимости поменять формулировки гипотез, удалить свидетельства и аргументы, не представляющие ценности.
5. Сделать предварительные заключения об относительной вероятности каждой из гипотез. Продолжить анализ, стараясь опровергнуть каждую гипотезу, а не доказать ее.
6. Оценить насколько чувствительно полученное заключение относительно немногих свидетельств. Оценить последствия для проведенного анализа в случае, если свидетельство ошибочное, ведущее к заблуждению или неправильно интерпретированное.
7. Подготовить отчет с заключениями. Обсудить относительную вероятность всех гипотез, а не только самой вероятной.
8. Определить ключевые моменты для дальнейшего наблюдения, которые могут привести к переоценке ситуации.



<https://www.cia.gov/library/center-for-the-study-of-intelligence/csi-publications/books-and-monographs/psychology-of-intelligence-analysis/PsychofIntelNew.pdf>

Пример матрицы с оценкой гипотез

Факты



	Тип источника Уровень доверия Актуальность	Гипотеза 1 связана с планом проведения экспериментов по ядерному оружию	Гипотеза 2 может быть объяснена исследованиями в гражданских целях
Доказательство 1: известная нам способ- ность обогащать уран является мотивом приобретения высокоско- ростных взрывателей	Предположение. Средняя. Высокая.	Согласуется.	Согласуется.
Доказательство 2: закупки осуществлялись через импортно-экспорт- ную компанию	Логический вывод. Высокая. Средняя.	Согласуется.	Согласуется в меньшей степени.
Доказательство 3: возле склада замечена военная охрана.	Данные фоторазведки. Высокая. Средняя.	Согласуется.	Согласуется в меньшей степени.
Доказательство 4: для приобретения высокоскоростных взрывателей использова- лись тайные каналы.	Агентурная разведка. Новый источ- ник на стадии проверки. Высокая.	Согласуется.	Согласуется в еще меньшей степени.
Доказательство 5: обнаружен шифрованный обмен военной информа- цией между складом и верховным командова- нием.	Радиотехни- ческая разведка. Высокая. Высокая.	Согласуется.	Согласуется в еще меньшей степени.



Гипотезы



Поддерживают
ли факты
гипотезы?

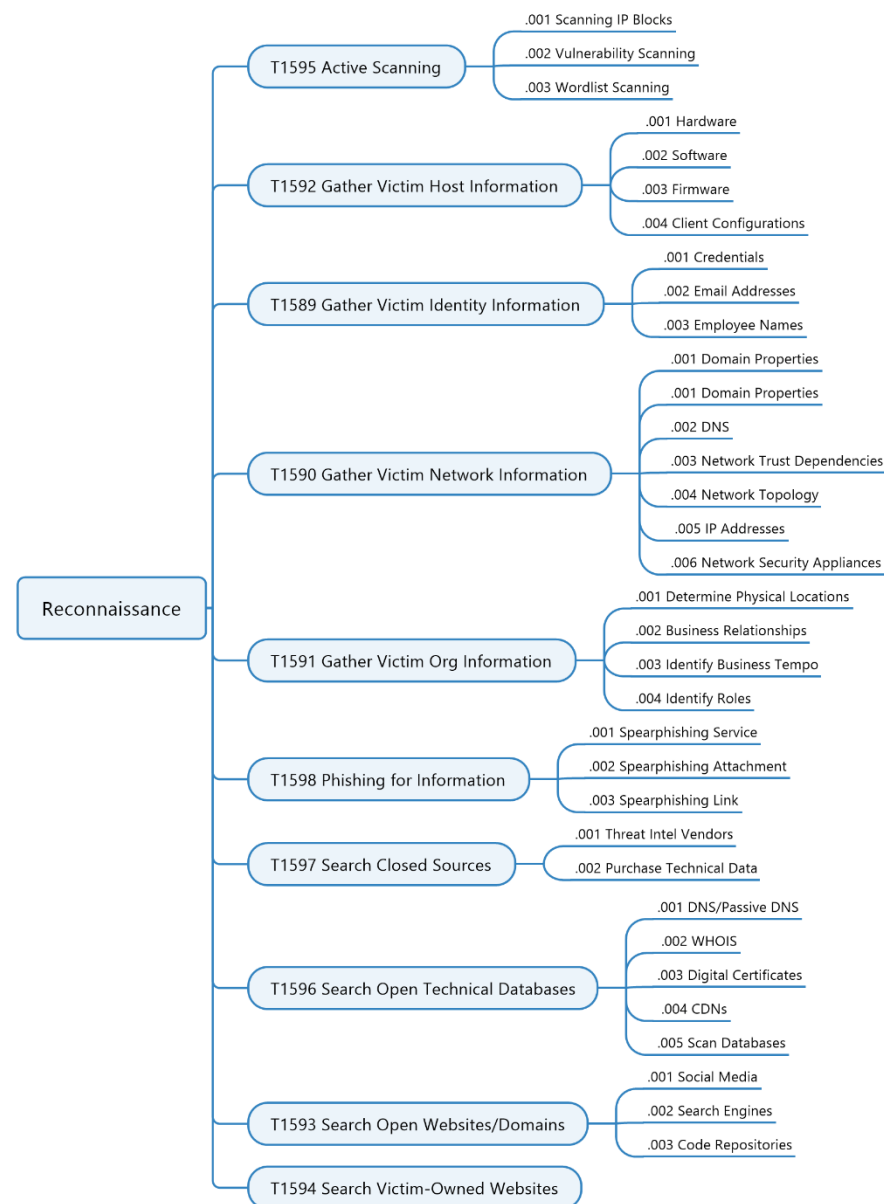
Принцип МЕСЕ

- Одним из полезных принципов формирования набора гипотез является МЕСЕ (mutually exclusive collectively exhaustive — взаимно исключающие, совместно исчерпывающие).

Задачи OSINT в рамках тестирования защищенности

1. Выявление хостов, сервисов.
2. Выявление имен учетных записей.
3. Сбор информации для определения возможных сценариев атак.

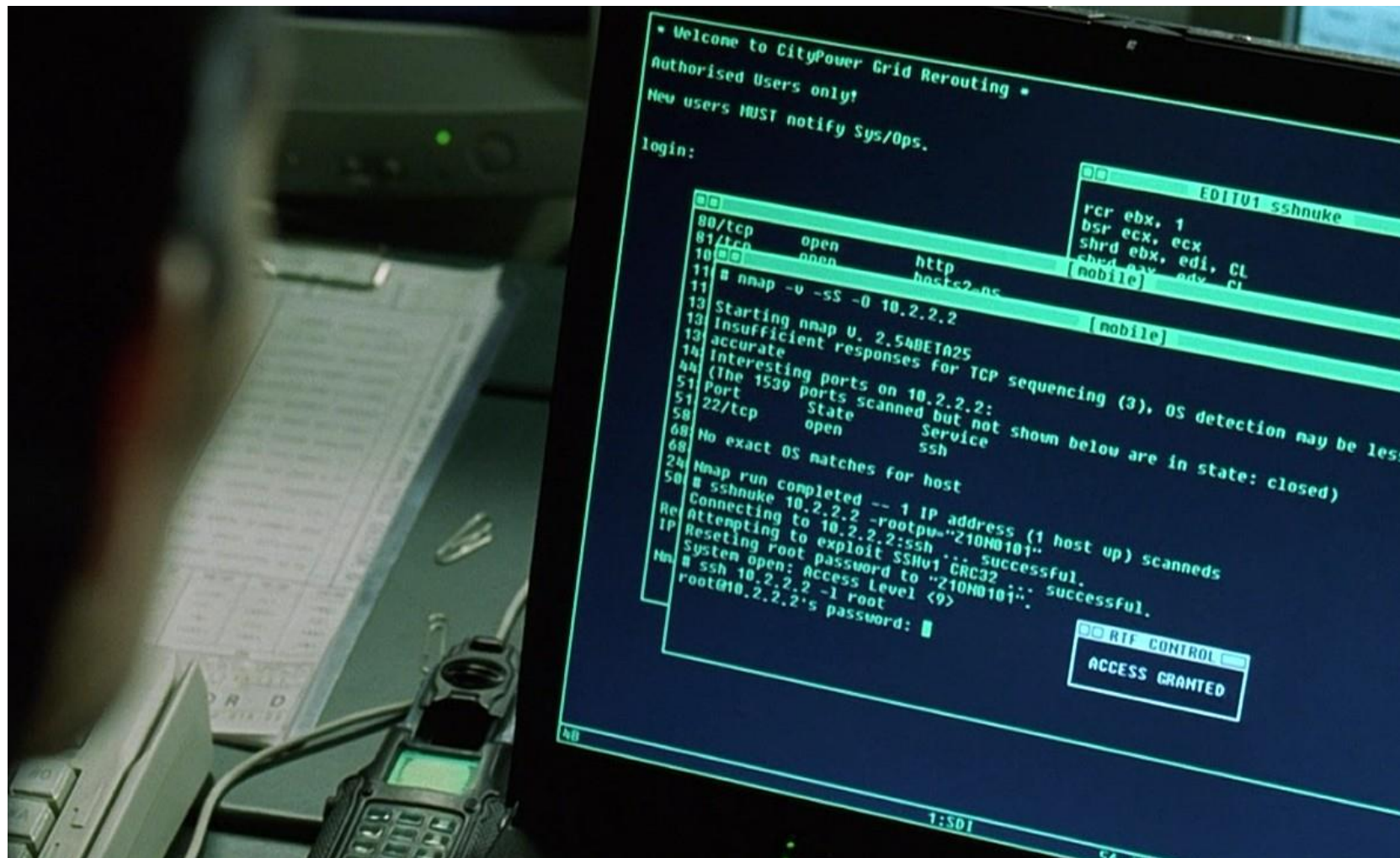
Разведка в MITRE ATT&CK



Разберем ключевые приемы

T1595.001 Scanning IP Blocks

31



Самые популярные ключи nmap

nmap 192.168.1.100	Сканирование 1000 портов одного узла
nmap -v 192.168.1.100	Сканирование с подробной выдачей информации
nmap -F 192.168.1.100	Сканирование 100 портов
nmap --reason 192.168.1.100	Показать состояние портов
nmap -p U:53 192.168.1.100	Просканировать UDP-порта 53
nmap -v -O --osscan-guess 192.168.1.100	Определить версии ОС
nmap -sV 192.168.1.100	Определить версии портов

Важные параметры для ускорения процессам сканирования в больших сетях: <https://nmap.org/man/ru/man-performance.html>

T1595.002 Vulnerability Scanning

**Тема следующего
занятия**

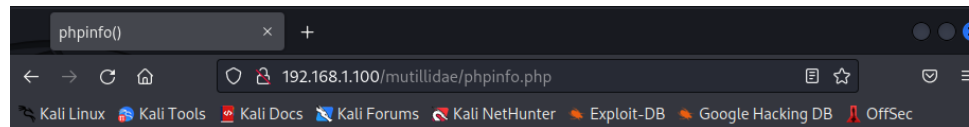


T1595.003 Wordlist Scanning

- Поиск страниц и директорий веб-приложений с помощью словарей.
- DIRB:
dirb <http://192.168.1.100/dvwa>
- Metasploit HTTP DIR_SCANNER
use auxiliary/scanner/http/dir_scanner
msf auxiliary(dir_scanner) >set dictionary
/usr/share/wordlists/dirb/common.txt
msf auxiliary(dir_scanner) >set rhosts 192.168.1.100
msf auxiliary(dir_scanner) > set path /dvwa
msf auxiliary(dir_scanner) >exploit

T1592 Gather Victim Host Information

- Пример: phpinfo.php



SERVER["argc"]	0
ENV["REDIRECT_HANDLER"]	php5-cgi
ENV["REDIRECT_STATUS"]	200
ENV["HTTP_HOST"]	192.168.1.100
ENV["HTTP_USER_AGENT"]	Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0
ENV["HTTP_ACCEPT"]	text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,*/*;q=0.8
ENV["HTTP_ACCEPT_LANGUAGE"]	en-US,en;q=0.5
ENV["HTTP_ACCEPT_ENCODING"]	gzip, deflate
ENV["HTTP_CONNECTION"]	keep-alive
ENV["HTTP_COOKIE"]	PHPSESSID=d0d616651f77851c0c9d48dc4ed389ea
ENV["HTTP_UPGRADE_INSECURE_REQUESTS"]	1
ENV["PATH"]	/usr/local/bin:/usr/bin:/bin
ENV["SERVER_SIGNATURE"]	<address>Apache/2.2.8 (Ubuntu) DAV/2 Server at 192.168.1.100 Port 80</address>
ENV["SERVER_SOFTWARE"]	Apache/2.2.8 (Ubuntu) DAV/2
ENV["SERVER_NAME"]	192.168.1.100
ENV["SERVER_ADDR"]	192.168.1.100
ENV["SERVER_PORT"]	80
ENV["REMOTE_ADDR"]	192.168.1.10
ENV["DOCUMENT_ROOT"]	/var/www/
ENV["SERVER_ADMIN"]	webmaster@localhost
ENV["SCRIPT_FILENAME"]	/var/www/mutillidae/phpinfo.php
ENV["REMOTE_PORT"]	50006
ENV["REDIRECT_URL"]	/mutillidae/phpinfo.php
ENV["GATEWAY_INTERFACE"]	CGI/1.1
ENV["SERVER_PROTOCOL"]	HTTP/1.1
ENV["REQUEST_METHOD"]	GET
ENV["QUERY_STRING"]	no value
ENV["REQUEST_URI"]	/mutillidae/phpinfo.php
ENV["SCRIPT_NAME"]	/mutillidae/phpinfo.php
ENV["ORIG_SCRIPT_FILENAME"]	/usr/lib/cgi-bin/php
ENV["ORIG_PATH_INFO"]	/mutillidae/phpinfo.php
ENV["ORIG_PATH_TRANSLATED"]	/var/www/mutillidae/phpinfo.php

T1589 Gather Victim Identity Information

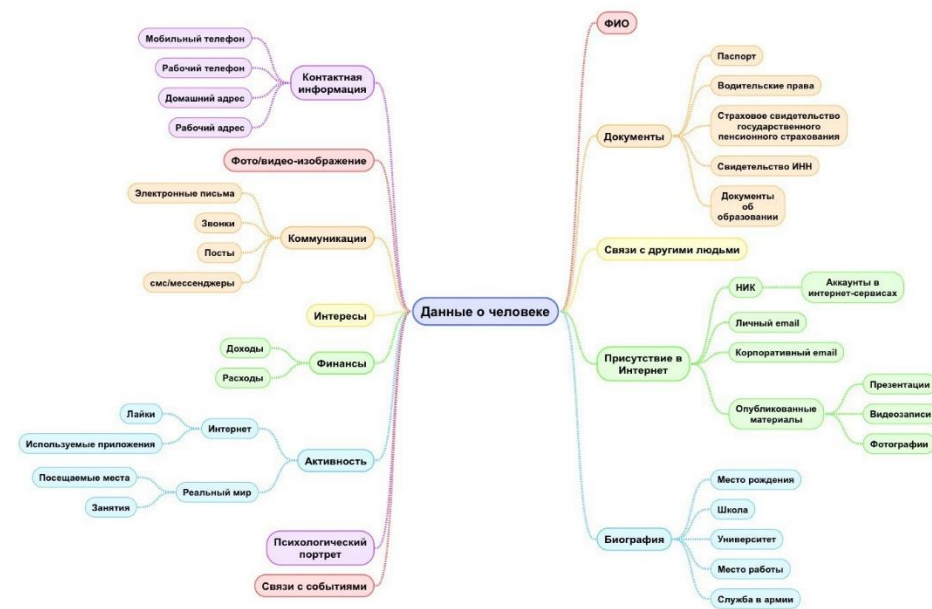
- Поиск адресов электронной почты в поисковиках.
- theHarvester — это инструмент для сбора e-mail адресов, имён поддоменов, виртуальных хостов, открытых портов/банеров и имён работников из различных открытых источников



theHarvester

Полезная информация о человеке для хакера

- Полное имя
- Имя учетной записи в корпоративных системах
- Должность
- Все, что можно использовать в атаках социальной инженерии



T1596.001 DNS/Passive DNS

DNS RECORDS CHEAT SHEET - CONSTELLIX

A (address)

1

A (address) - Most commonly used to map a fully qualified domain name (FQDN) to an IPv4 address and acts as a translator by converting domain names to IP addresses. ✓

AAAA (quad A)

2

AAAA (quad A) - Similar to A Records but maps to an IPv6 address (smartphones prefer IPv6, if available). ✓

ANAME

3

ANAME - This record type allows you to point the root of your domain to a hostname or FQDN. ✓

CNAME

4

CNAME (Canonical Name) - An alias that points to another domain or subdomain, but never an IP address. Alias record mapping FQDN to FQDN, multiple hosts to a single location. This record is also good for when you want to change an IP address over time as it allows you to make changes without affecting user bookmarks, etc. ✓

SOA (start of authority)

5

SOA (Start of Authority) - Stores information about domains and is used to direct how a DNS zone propagates to secondary name servers. ✓

NS (name server)

6

NS (name server) - Specifies which name servers are authoritative for a domain or subdomains (these records should not be pointed to a CNAME). ✓

MX (mail exchange)

7

MX (Mail eXchange) - Uses mail servers to map where to deliver email for a domain (should point to a mail server name and not to an IP address). ✓

TXT (text)

8

TXT (text) - Allows administrators to add limited human and machine-readable notes and can be used for things such as email validation, site, and ownership verification, framework policies, etc., doesn't require specific formatting. ✓

SRV (service)

9

SRV (service) - Allows services such as instant messaging or VoIP to be directed to a separate host and port location. ✓

SPF (sender policy framework)

10

SPF (sender policy framework) - Helps prevent email spoofing and limits spammers. ✓

PTR (pointer)

11

PTR (pointer) - A reverse of A and AAAA records, which maps IP addresses to domain names. These records require domain authority and can't exist in the same zone as other DNS record types (put in reverse zones). ✓

QUICK TIP

12

Tip: Always check for typos and mistakes when entering your DNS record information, especially your IPs. The Zone Config File is a good place to check your work and spot any mistyped information. ✓



T1596.001 DNS/Passive DNS

- Запись A: `dig uc-echelon.ru`
- Запись MX: `dig uc-echelon.ru MX`
- Запись NS: `dig uc-echelon.ru NS`
- Обратный DNS-запрос `dig +noall +answer -x 8.8.8.8`
- DNS-запрос к определенному DNS-серверу `dig uc-echelon.ru @8.8.8.8`
- Поиск доменов 3-го уровня с помощью словарей: `fierce`

T1596. WHOIS

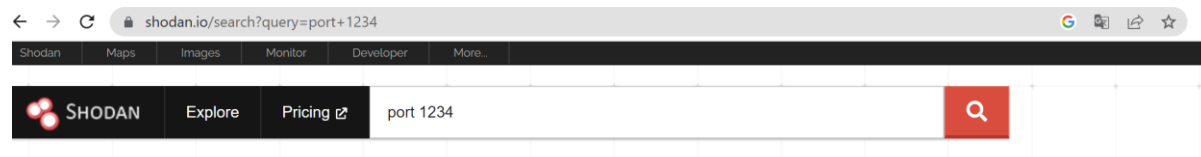
- Типовой алгоритм выявления других целей, связанных с организацией:
 1. Определение целевого IP-адреса (прямой DNS-запрос)
 2. Использование whois для определения диапазона сети, к которому принадлежит данный IP-адрес:

whois ip_address



T1596.005 Scan Databases

- <https://www.shodan.io/>



TOTAL RESULTS

4,441

TOP COUNTRIES



United States	3,923
Malaysia	212
France	78

View Report View on Map

Partner Spotlight: Looking for a place to store all the Shodan data

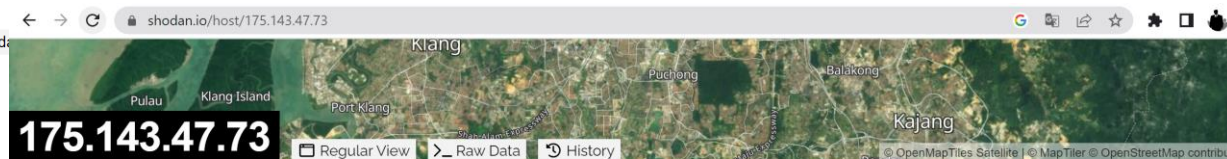
175.143.47.73

TMNST

Malaysia, Kuala Lumpur

HTTP/1.1 200 OK
Content-Length: 12002
Content-type: text/html
Server: WebSocket++/0.7.0

```
<!doctype html>
<html lang="en-us">
  <head>
    <meta http-equiv="content-type" c
    <meta http-equiv="X-UA-Compatible
    <meta name="viewport"....
```



// LAST SEEN: 2023-03-08

General Information

Country	Malaysia
City	Kuala Lumpur
Organization	TMNST
ISP	TM Net, Internet Service Provider
ASN	AS4788

Open Ports

11	13	15	17	19	20	21	22	26
37	43	49	53	70	79	80	81	82
85	91	96	97	98	99	100	102	104
106	110	113	119	143	154	175	179	199
221	222	264	311	340	389	443	444	450

T1593.001 Social Media

- <https://vk.com/friends?act=find>
- аналогичный функционал в других соцсетях

Пол

- ☐ Женский
- ☐ Мужской
- ☒ Любой

Семейное положение

Выберите статус ▾

- ☒ с фотографией
- ☐ сейчас на сайте

Жизненная позиция ▾

Работа ▲

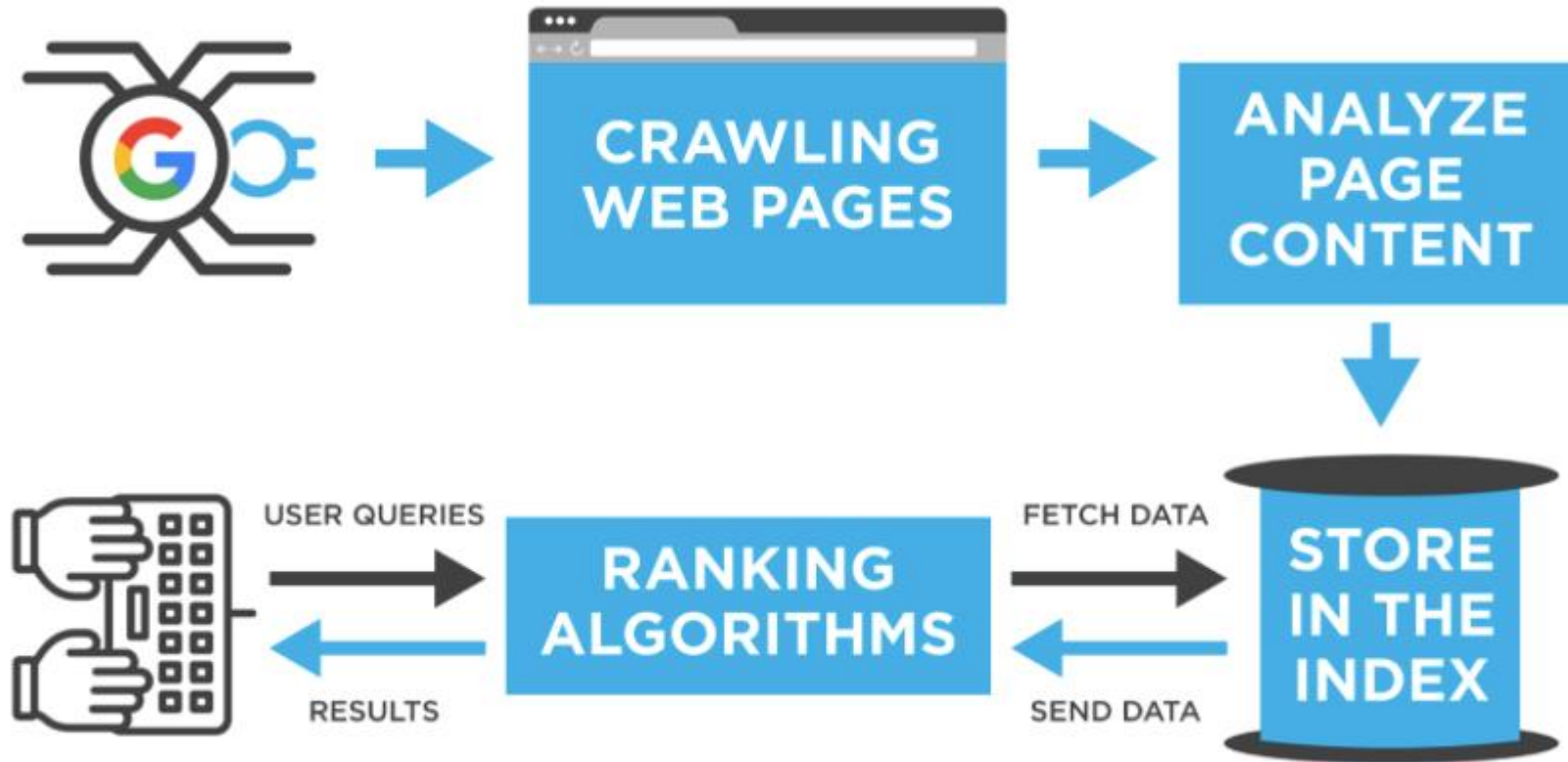
Эшелон

Должность

Военная служба ▾

Дополнительно ▾

T1593.002 Search Engines



Операторы Google

- [слово] **OR** [слово] – логическое “или”
- +[слово] обязательное вхождение слова
- -[слово] обязательное отсутствие слова
- **Cache:**[www.example.ru] поиск кэшированной версии страницы
- **Allinurl:**[слово1] [слово2] [слово3] – поиск страниц, в URL которых встречаются все указанные слова
- **Site:**[www.example.ru] – поиск только на указанном сайте
- **Allintitle:**[слово1] [слово2] [слово3] – поиск страниц со всеми указанными словами, находящимися в области <title>
- **Filetype:**[расширение файла] – находит файлы с заданным расширением
- “[слово1] [слово2]” – поиск страниц, содержащих точную фразу.

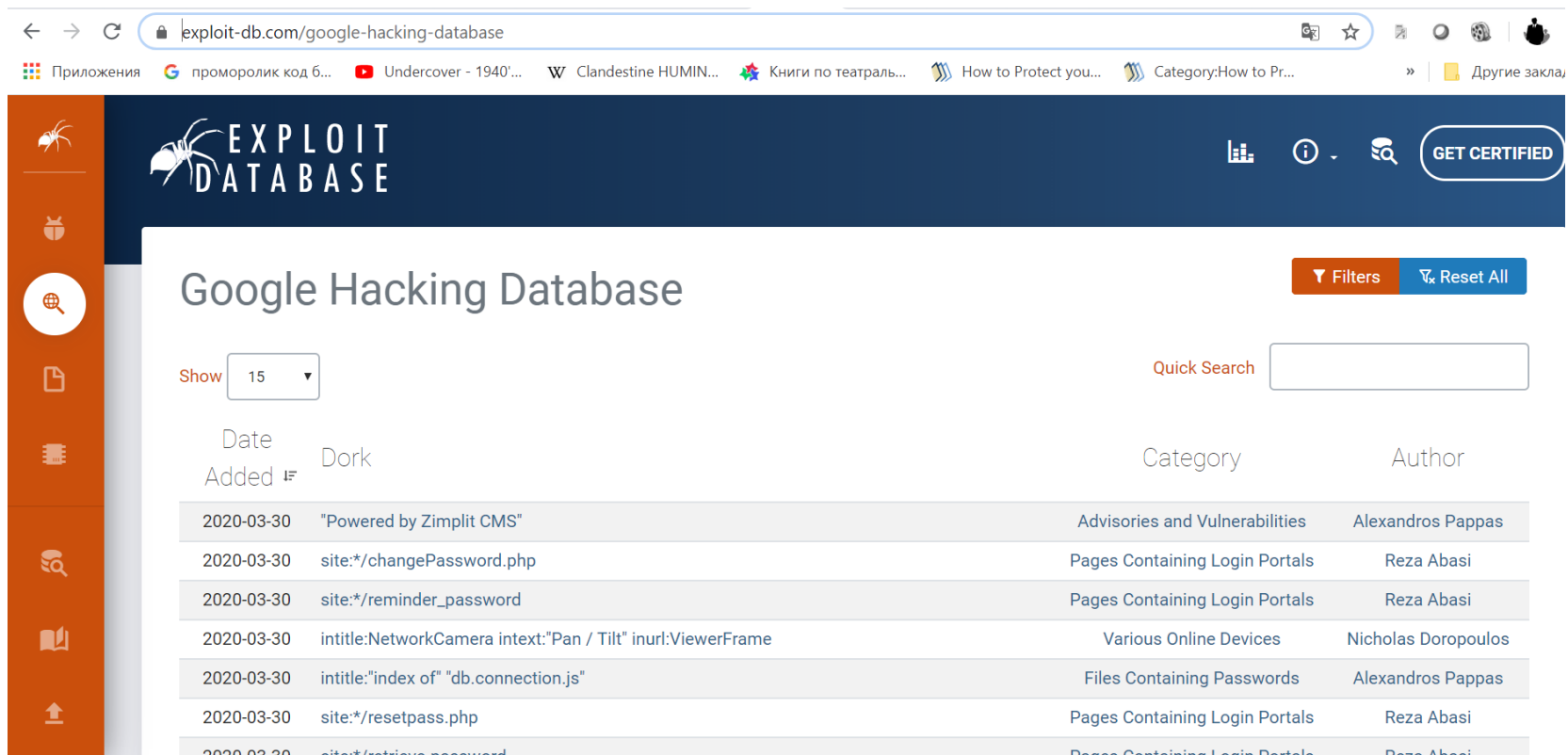
Продвинутый поиск для ленивых

http://www.google.ru/advanced_search

Возможности Google для хакеров

- Информацию об уязвимостях и эксплойтах
- Web-серверы, содержащие уязвимости
- Пароли, хэши паролей
- Директории, ставшие достоянием общественности из-за ошибки администратора
- Страницы, использующиеся для входа в Web-приложение

Google Hacking Database



exploit-db.com/google-hacking-database

Приложения | проморолик код 6... | Undercover - 1940'... | Clandestine HUMIN... | Книги по театраль... | How to Protect you... | Category:How to Pr... | Другие закла...

EXPLOIT DATABASE

GET CERTIFIED

Google Hacking Database

Filters Reset All

Show 15

Quick Search

Date Added	Dork	Category	Author
2020-03-30	"Powered by Zimplit CMS"	Advisories and Vulnerabilities	Alexandros Pappas
2020-03-30	site:*/changePassword.php	Pages Containing Login Portals	Reza Abasi
2020-03-30	site:*/reminder_password	Pages Containing Login Portals	Reza Abasi
2020-03-30	intitle:NetworkCamera intext:"Pan / Tilt" inurl:ViewerFrame	Various Online Devices	Nicholas Doropoulos
2020-03-30	intitle:"index of" "db.connection.js"	Files Containing Passwords	Alexandros Pappas
2020-03-30	site:*/resetpass.php	Pages Containing Login Portals	Reza Abasi
2020-03-30	site:*/retrievepassword	Pages Containing Login Portals	Reza Abasi

<https://www.exploit-db.com/google-hacking-database>

T1593.003 Code Repositories

- Пароли
- Ключи для доступа к API

```
Pseudo Code
void -[ApplicationPatchingDetailsVC loginMethod1Tapped:](void * self,
void * _cmd, void * arg2) {
    var_8 = self;
    var_10 = _cmd;
    var_18 = 0x0;
    objc_storeStrong(var_18, arg2);
    var_19 = 0x0;
    rax = [var_8 usernameTextField];
    rax = [rax retain];
    var_48 = rax;
    rax = [rax text];
    rax = [rax retain];
    var_50 = rax;
    var_51 = LOBYTE(0x0);
    rax = [rax isEqualToString:@"Admin"];
    var_29 = 0x0;
    var_39 = 0x0;
    var_52 = LOBYTE(var_51);
    if ((LOBYTE(rax) & 0x1) == 0x0) {
    }
    else {
        rax = [var_8 passwordTextField];
        rax = [rax retain];
        var_28 = rax;
        var_29 = 0x1;
        rax = [rax text];
        rax = [rax retain];
        var_38 = rax;
        var_39 = 0x1;
        var_60 = @selector(isEqualToString:);
        var_68 = @"This!sA5Ecret";
        var_52 = LOBYTE([rax isEqualToString:rdx]);
    }
    var_69 = LOBYTE(var_52);
}
```

T1594. Search Victim-Owned Websites

- Интересная информация:
 - Имена сотрудников
 - Адреса электронной почты
 - Структура компании (дочерние предприятия)
 - Партнеры
 - Вакансии
- Помним об операторе Google “site: “
- Интерес могут представлять также сайты поставщиков/партнеров/СМИ, содержащих информацию об организации

robots.txt

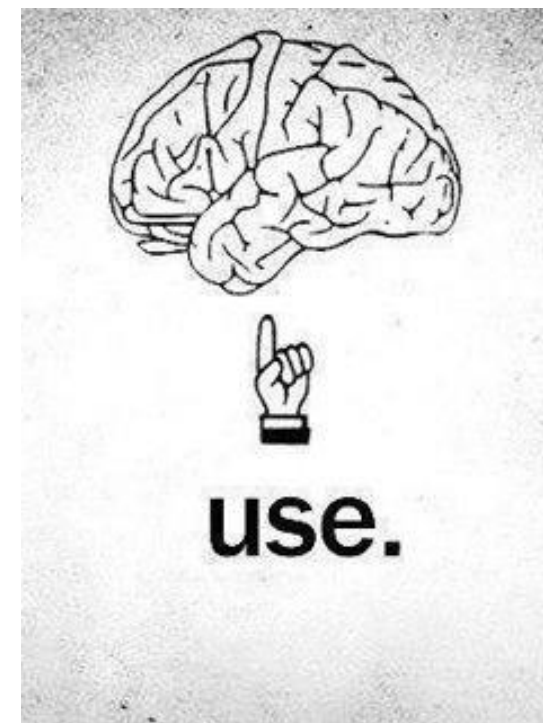
Самое интересное
для любого хакера



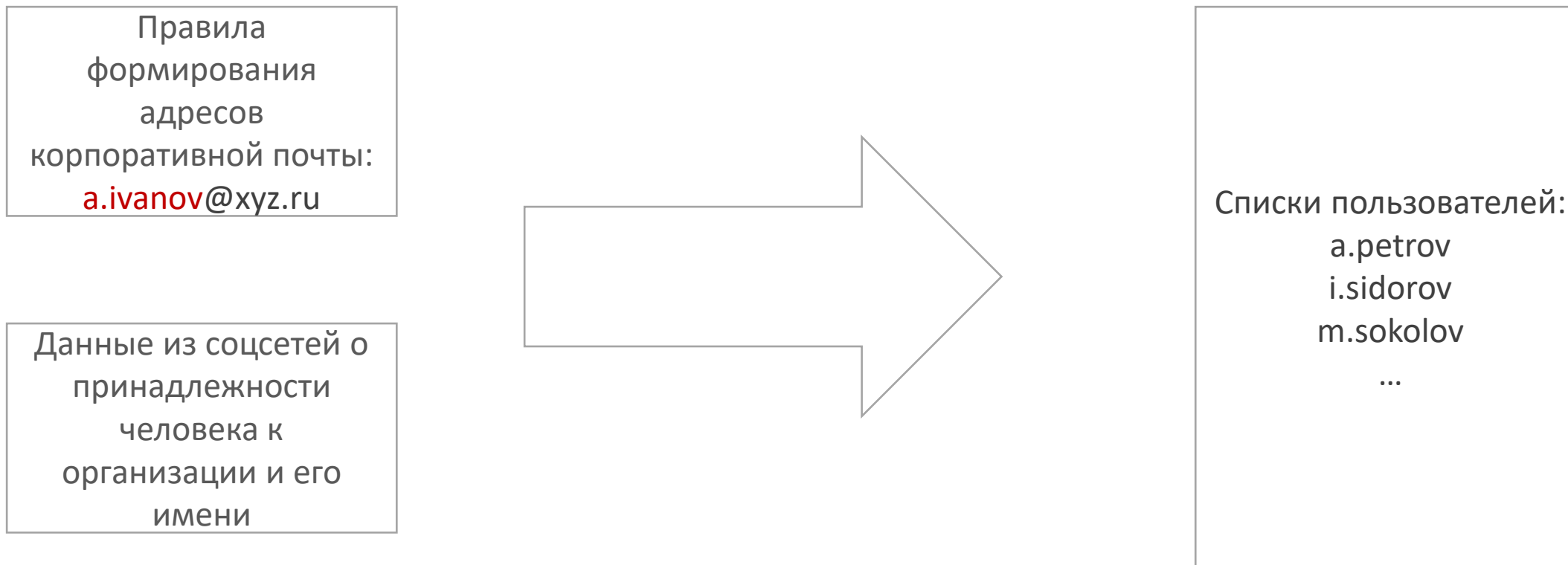
Яндекс поддерживает следующие директивы:

Директива	Что делает
User-agent *	Указывает на робота, для которого действуют перечисленные в <code>robots.txt</code> правила.
Disallow	Запрещает обход разделов или отдельных страниц сайта.
Sitemap	Указывает путь к файлу <code>Sitemap</code> , который размещен на сайте.
Clean-param	Указывает роботу, что URL страницы содержит параметры (например, UTM-метки), которые не нужно учитывать при индексировании.
Allow	Разрешает индексирование разделов или отдельных страниц сайта.
Crawl-delay	Задаёт роботу минимальный период времени (в секундах) между окончанием загрузки одной страницы и началом загрузки следующей. Рекомендуем вместо директивы использовать настройку скорости обхода в Яндекс Вебмастере.

Методы разведывательного анализа в рамках пентеста

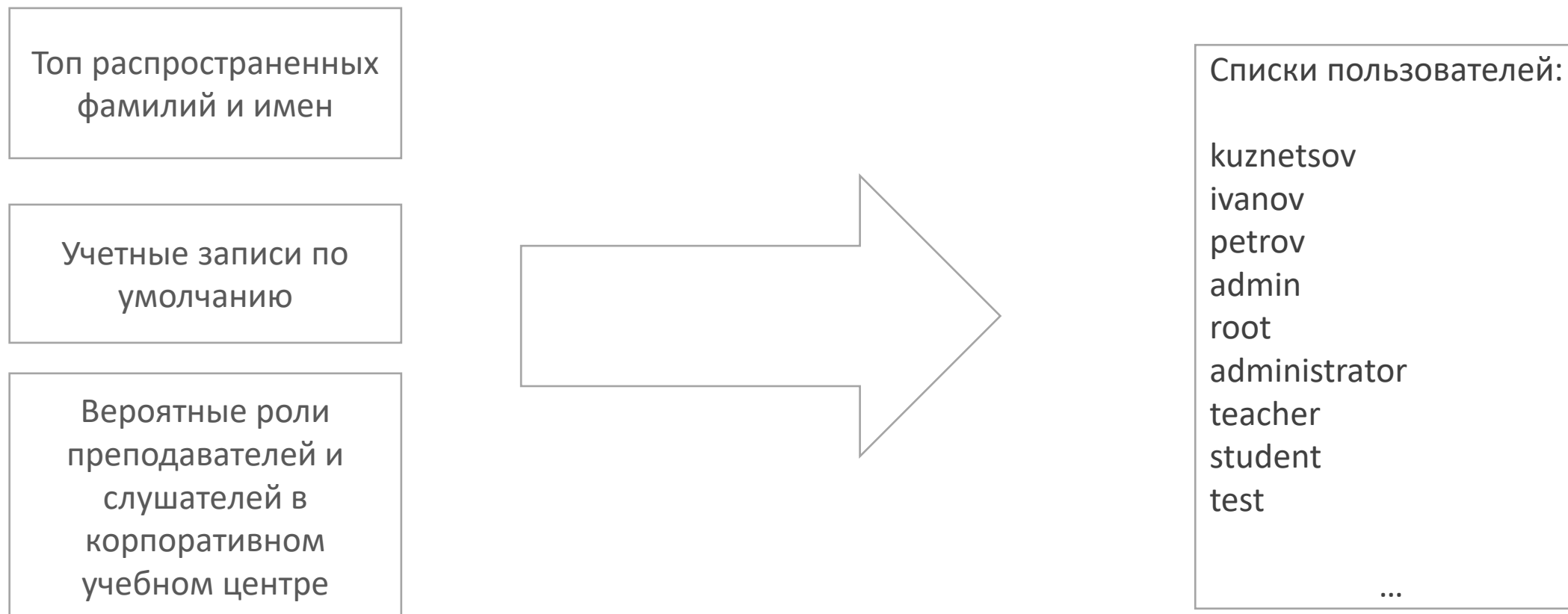


Выявление учетных записей



Использованный прием: анализ причинно-следственных связей

Проверка вероятных пользователей



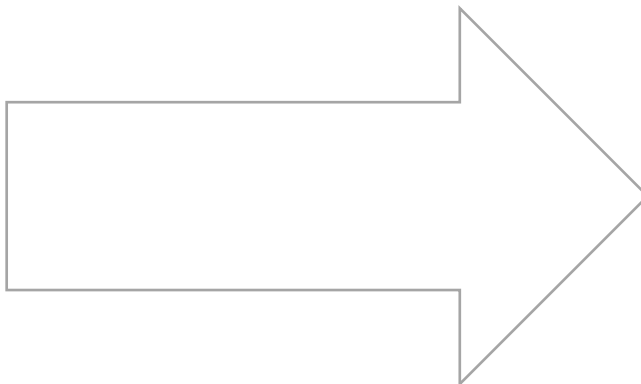
Использованный прием: тестирование гипотез

Определение версии CMS

Выявление web-портала у заказчика

Пресс-релиз подрядчика о том, что завершен проект с применением определенных решений

Информация от вендора, в какой период, какая версия продукта продавалась



Точная версия продукта, подходящая для поиска информации об уязвимостях

Использованный приемы: анализ причинно-следственных связей, хронология

Домашнее задание 2

1. Определить версии сетевых сервисов с помощью NMAP в Metasploitable 2.
2. Найти директории на web-серверах, запущенных на Metasploitable 2.
3. Определить имя и адрес почтового сервера учебного центра «Эшелон».

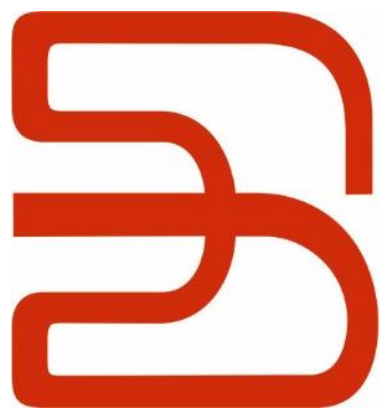
Echelon Eyes

Echelon Eyes



@ECHELONEYES

- Материалы курса: презентации, видео
- Новости об уязвимостях, инцидентах, эксплойтах, изменениях в нормативной базе



Эшелон

комплексная безопасность